

El framework propuesto no asume la seguridad desde una perspectiva estática, sino como un ecosistema dinámico y adaptativo diseñado específicamente para Proveedores de Servicios de Internet (ISP). Para ello, las funciones nucleares de Detectar (Detect – DE) y Responder (Respond – RS) del framework se fusionan de manera nativa con las directrices de continuidad tecnológica de la publicación especial NIST SP 800-34. Esta arquitectura permite transformar los estándares conceptuales en un flujo de control cuantitativo y rastreable a lo largo de todo el ciclo de gestión. [1]

2.1. Definición del Contexto e Incorporación Analítica de la Cadena de Suministro

La gestión estratégica del riesgo inicia con la delimitación del contexto operativo y la identificación de las amenazas. Para que el framework responda con precisión a la realidad de un ISP, la fase de identificación tradicional, basada únicamente en Activos, Amenazas y Vulnerabilidad, ha sido modificada mediante la inclusión analítica de un cuarto elemento crítico: la **Cadena de Suministro (Supply Chain)**. [2]

En el entorno de las telecomunicaciones, la infraestructura propia (enrutadores Core, enlaces de fibra óptica, sistemas de resolución DNS) mantiene una dependencia absoluta de factores exógenos. La cadena de suministro se integra en el modelo como una propiedad estructural que define y altera el entorno de la amenaza, considerando variables como:

- **Proveedores de Tránsito IP Superior (Upstream Providers):** Rutas de interconexión internacional y estabilidad del Backbone exógeno.
- **Infraestructura Crítica Compartida:** Servicios de suministro eléctrico, centros de datos de terceros y derechos de vía para tendidos de fibra.
- **Proveedores de Plataformas Lógicas:** Sistemas de software de aprovisionamiento, soluciones de facturación (BSS/OSS) y servicios en la nube interconectados.

La cadena de suministro se califica de forma independiente y actúa estrictamente como un **factor de incremento o amplificación del impacto**. Su presencia nunca reduce la vulnerabilidad basal; por el contrario, a mayor dependencia o menor control sobre un proveedor externo, mayor será la exposición técnica ante un ataque sistémico.

2.2. Modelado Matemático del Riesgo Inherente (RI)

La interacción de los elementos de la fase de identificación da origen al **Riesgo Inherente (RI)**, definido como el nivel de riesgo latente en la organización antes de la aplicación o consideración de cualquier salvaguarda o plan de mitigación activo. Para su cuantificación, se establecen escalas paramétricas que evalúan de forma independiente la probabilidad y el impacto. [3]

2.2.1. Variables y Escalas de Medición Basales

Las escalas discretas de 1 a 5 se adoptan por su uso extendido en modelos de gestión de riesgo y su facilidad de calibración operativa en entornos ISP

- **Frecuencia de la Amenaza (Am):** Probabilidad estimada de ocurrencia del ataque (ej. denegación de servicio DDoS, secuestro de rutas BGP). Escala entera: [1,5] (Desde muy baja hasta muy alta).
- **Nivel de Vulnerabilidad (V):** Severidad de las debilidades técnicas o falta de controles basales en la infraestructura. Escala entera: [1,5] (Desde mínima hasta crítica).

- **Criticidad del Activo (A):** Valoración del recurso de red afectado en función de la operación del ISP. Escala entera: [1,5] (Desde despreciable hasta crítica).
- **Factor de Cadena de Suministro (CS):** Coeficiente multiplicador que mide el nivel de dependencia de terceros. Escala continua: [1.0 a 1.5] . Si el servicio depende en su totalidad de la infraestructura propia del ISP, CS = 1.0 (no amplifica el impacto); si depende de infraestructura externa sin redundancia verificable, CS = 1.5 (amplifica el impacto potencial en un 50%).

2.2.2. Ecuaciones del Riesgo Inherente

La **Probabilidad Inherente (P_I)** se determina mediante el cruce de la amenaza y la vulnerabilidad:

$$P_I = Am \times V$$

$$P_I \in [1, 25]$$

El **Impacto Inherente (I_I)** formaliza analíticamente la amplificación producida por la cadena de suministro sobre el activo:

$$I_I = A \times CS$$

$$I_I \in [1, 7.5]$$

Multiplicando ambos vectores, se formula la ecuación final del **Riesgo Inherente (R_I)**:

$$RI = PI \times II$$

$$RI = (Am \times V) \times (A \times CS)$$

$$R_I \in [1, 187.5]$$

2.3. Función: IDENTIFICAR (Identify – ID) y el Reconocimiento del Entorno Operativo del ISP

Antes de desplegar cualquier mecanismo de defensa, el framework establece como condición necesaria que la organización comprenda con precisión su propio entorno. La función Identify del NIST CSF 2.0 formaliza este principio: sin un inventario claro de activos, amenazas y dependencias, cualquier control aplicado posteriormente carece de dirección y resulta difícilmente priorizable [1].

En el contexto de un ISP, esta función se materializa en el reconocimiento sistemático de la infraestructura crítica de red, la identificación de los activos de mayor criticidad operativa y la comprensión de las interdependencias con terceros que conforman la cadena de suministro. Este proceso alimenta directamente las variables de entrada del modelo matemático del Riesgo Inherente (RI), dotando al framework de una base empírica y trazable desde su punto de origen.

2.4. . Función: PROTEGER (Protect – PR) y la Implementación de Salvaguardas Basales

Una vez identificado el entorno, el framework despliega la función Protect, cuyo propósito es reducir la probabilidad de que una amenaza llegue a materializarse mediante la implementación de salvaguardas técnicas y organizativas [4]. A diferencia de las fases reactivas del ciclo, esta función opera de forma preventiva y continua.

En el entorno de un ISP, las subcategorías de mayor relevancia operativa son las siguientes:

Control de Acceso (PR.AC): Gestión de identidades y privilegios sobre los sistemas de gestión de red, plataformas BSS/OSS y accesos administrativos a la infraestructura Core, garantizando el principio de mínimo privilegio.

Concienciación y Formación (PR.AT): Programas de capacitación continua orientados al personal técnico y operativo, con énfasis en la detección temprana de amenazas asociadas a la cadena de suministro.

Seguridad de los Datos (PR.DS): Implementación de controles de integridad y cifrado sobre los flujos de información crítica, incluyendo configuraciones de enrutamiento BGP y bases de datos de autenticación AAA.

Mantenimiento y Gestión de Vulnerabilidades (PR.MA / PR.PS): Aplicación sistemática de parches y actualizaciones sobre los sistemas de la infraestructura, reduciendo la superficie de ataque antes de que una amenaza pueda explotarla.

La madurez de implementación de estos controles se incorpora al framework como un insumo directo para la calibración del Coeficiente de Eficiencia de Control (C), descrito en la sección 2.6, cerrando así el vínculo entre la fase preventiva y el modelo cuantitativo de riesgo residual.

2.5. Función: DETECTAR (Detect – DE) y su Operacionalización en el Monitoreo Continuo

Una vez establecido el riesgo latente, el framework despliega la fase de **Monitoreo Continuo**, la cual se nutre de los flujos de telemetría de la red. En esta etapa se introduce de forma nativa la función **Detectar (DE)** de NIST CSF 2.0, cuyo objetivo es capturar anomalías en tiempo real y medir con precisión matemática el comportamiento de los vectores de ataque. [4]

Las subcategorías técnicas se adaptan a la infraestructura del ISP bajo los siguientes criterios:

- **Monitoreo Continuo de Seguridad (DE.CM):** * *DE.CM-01*: Supervisión automatizada de flujos de red troncal mediante protocolos NetFlow/sFlow, estabilidad de tablas de enrutamiento BGP y tasas de resolución de peticiones DNS.
 - *DE.CM-06*: Monitoreo activo de los endpoints y APIs de proveedores de la cadena de suministro, estableciendo alertas tempranas ante anomalías detectadas en infraestructuras de terceros interconectadas.
- **Análisis de Acontecimientos Adversos (DE.AE):**
 - *DE.AE-03*: Motores de correlación lógicos (SIEM/XDR) que cruzan los logs de la infraestructura Core interna con las notificaciones de incidentes emitidas por los proveedores externos.
 - *DE.AE-08*: Algoritmos de umbralización que ejecutan la transición automática de un evento anómalo a la declaración formal de un incidente de ciberseguridad, registrando cronométricamente el Tiempo Medio de Detección (MTTD).

Qué se Mide y Cómo se Mide en el ISP

La función *Detect* suministra los datos empíricos necesarios para cuantificar la **Probabilidad** y la **Exposición** dentro del cálculo del riesgo operativo.

Métricas e Indicadores Técnicos (Qué se mide):

- *Tiempo Medio de Detección (MTTD - Mean Time To Detect)*: Latencia temporal entre el inicio de una anomalía (ataque DDoS, secuestro de rutas BGP) y su identificación por el equipo de seguridad.
- *Tasa de Falsos Positivos/Negativos*: Efectividad de las reglas de correlación del SIEM.
- *Índice de Visibilidad de Terceros (IVT)*: Porcentaje de proveedores de la cadena de suministro integrados en el ecosistema de alertas tempranas del ISP.

Fuentes de Verificación Operativa (Cómo se mide):

- Registros centralizados (Logs) de enrutadores Core, firewalls perimetrales y sistemas de mitigación DDoS.
- Alertas automatizadas procedentes de sondas IDS/IPS y plataformas de monitoreo de disponibilidad.
- Reportes de telemetría e incidentes suministrados de forma coordinada por los proveedores de la cadena de suministro.
- **Nota Metodológica del Riesgo**: En este punto del flujo, la organización está expuesta al **Riesgo Inherente**. La función *Detect* cuantifica la existencia y magnitud de la amenaza materializada, pero no altera su impacto.

2.4. Función: RESPONDER (Respond – RS) y la Jerarquía de Contingencia bajo NIST SP 800-34

Al declararse formalmente un incidente, se acciona de inmediato la fase de **Respuesta y Recuperación**. Esta etapa aloja la función **Responder (RS)** de NIST CSF 2.0 y se articula bajo la estricta jerarquía de planes de contingencia para sistemas de información normados por **NIST SP 800-34**. Con el fin de evitar la superposición conceptual común en las organizaciones de telecomunicaciones, el framework adopta una diferenciación estructural basada en tres capas de control:

1. **Plan de Respuesta a Incidentes (IRP - Incident Response Plan)**: Actúa en la capa táctica de ciberseguridad (*NIST CSF RS.MA / RS.MI*). Mitiga ataques dirigidos en fase temprana mediante contención rápida (ej. bloqueos perimetrales, aislamiento de hosts comprometidos o mitigación de denegaciones de servicio DDoS a través de centros de depuración de tráfico o *scrubbing centers*).
2. **Plan de Recuperación ante Desastres (DRP - Disaster Recovery Plan)**: Se activa en la capa técnica cuando el incidente rompe las barreras del IRP e impacta la integridad física o lógica de las plataformas de TI del ISP (ej. secuestro por Ransomware de bases de datos de autenticación AAA o sistemas de aprovisionamiento). Su enfoque es la restauración de sistemas y servicios informáticos utilizando entornos alternos o respaldos seguros (*NIST SP 800-34 / DRP*).
3. **Plan de Continuidad de Operaciones (COOP - Continuity of Operations Plan)**: Se sitúa en la capa estratégica de la infraestructura crítica. Un ISP no requiere únicamente un plan de continuidad de negocio corporativo genérico, sino un **COOP** enfocado en mantener la misión esencial e irrenunciable de la organización: la provisión y estabilidad de la conectividad de red. Siguiendo las directrices de NIST SP 800-34, el COOP aglutina y coordina el ecosistema de planes lógicos ante caídas masivas de nodos Core o afectaciones severas de la cadena de suministro superior, conmutando de forma autónoma la operación hacia rutas y tránsitos IP redundantes de contingencia.

Qué se Mide y Cómo se Mide en el ISP

La función *Respond* actúa de manera directa sobre la variable de **Impacto** en el análisis de riesgo.

- **Métricas e Indicadores Técnicos (Qué se mide):**

- *Tiempo Medio de Respuesta o Mitigación (MTTR - Mean Time To Respond / Mitigate)*: Ventana de tiempo transcurrida entre la declaración oficial del incidente y su contención efectiva.
- *Porcentaje de Degradación del Servicio*: Pérdida de rendimiento de la red o throughput durante el evento.
- *Eficiencia de Aislamiento*: Tiempo requerido para cortar la comunicación con un proveedor de la cadena de suministro comprometido o suspender un segmento de red infectado.

- **Fuentes de Verificación Operativa (Cómo se mide):**

- Bitácoras y registros de auditoría de los sistemas de orquestación de respuesta (plataformas de ticketing).
- Informes post-incidente (*Post-Mortem*) detallando las marcas de tiempo de las acciones ejecutadas.
- Reportes de disponibilidad del Centro de Operaciones de Red (NOC) y del Centro de Operaciones de Seguridad (SOC).

Nota Metodológica del Riesgo: Al concluir las acciones de la función *Respond*, los controles y planes de mitigación han interactuado con la amenaza. Lo que se evalúa en esta etapa final del ciclo es el **Riesgo Residual**.

Para evaluar el impacto real de estos planes como barrera de defensa, el framework introduce el **Coeficiente de Eficiencia de Control (η_c)**. Cada uno de los tres planes recibe una calificación de madurez e implementación real (M) en un rango continuo de [0, 1] (donde 0 es inexistente y 1 representa un plan totalmente automatizado, probado y auditado).

El valor de madurez M se obtiene mediante auditorías técnicas, pruebas de simulación y ejercicios documentados de activación de planes.

Se asignan pesos específicos (w) a cada plan que reflejan su relevancia estratégica en la continuidad del ISP, cumpliendo con la condición de normalización $\sum w_i = 1$:

- Peso del IRP (w_{IRP}): 0.25 (Capa táctica y contención rápida).
- Peso del DRP (w_{DRP}): 0.35 (Restauración de plataformas lógicas e información).
- Peso del COOP (w_{COOP}): 0.4 (Conmutación de enlaces de conectividad esenciales y tránsitos superiores).

El cálculo formal del coeficiente de eficiencia se define como:

2.5. Cuantificación del Riesgo de Control (R_c) y Determinación del Riesgo Residual (R_R)

El núcleo matemático del framework radica en el uso de los planes de contingencia no como meros reductores del impacto posterior, sino como componentes determinantes del **Riesgo de Control** (R_c), entendido cuantitativamente como la fuerza o capacidad de mitigación absoluta que las salvaguardas oponen ante la exposición inicial.

El Riesgo de Control se extrae directamente de la acción de la eficiencia de los controles sobre el riesgo total latente:

$$R_c = R_I \times n_c$$

Finalmente, el **Riesgo Residual** (R_R) representa el valor real de riesgo remanente en la operación del ISP tras el despliegue del ecosistema defensivo. Aplicando el principio de balance estructural del modelo, su cálculo se formaliza mediante la sustracción directa:

$$R_{Residual} = R_I - R_c$$

Al sustituir el Riesgo de Control por su definición expandida, se demuestra la consistencia matemática del tránsito hacia el riesgo residual:

$$R_{Residual} = R_I - (R_I \times n_c)$$

$$R_{Residual} = R_I \times (1 - n_c)$$

Esta relación paramétrica garantiza que los datos cronométricos de los incidentes —tales como el Tiempo Medio de Respuesta (MTTR)— recopilados en la fase de respuesta fluyan de manera vertical hacia la fase de **Mejora Continua**. Esto permite calibrar los umbrales de detección y optimizar de forma perpetua el nivel de madurez de los controles frente a futuras amenazas en la cadena de suministro del ISP.

Referencias

- [1] M. Peña, “How to Adapt an Existing Security Program to the NIST Cybersecurity Framework 2.0,” *Isecauditors.com*, Dec. 29, 2025.
<https://blog.isecauditors.com/en/how-to-adapt-an-existing-security-program-to-the-nist-cybersecurity-framework-2-0> (accessed June 02, 2026).
- [2] Glocert International, “NIST CSF 2.0 Services,” *Glocert International*, 2024.
<https://www.glocertinternational.com/services/cybersecurity-assessments/nist-csf-2-0#:~:text=Developed%20by%20the%20National%20Institute%20of%20Standards,of%20all%20sizes%2C%20sectors%2C%20and%20maturity%20levels.> (accessed June 02, 2026).
- [3] NIST, “Guide for Conducting Risk Assessments,” NIST, Sept. 2012. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-30r1.pdf>
- [4] “El Marco de Seguridad Cibernética (CSF) 2.0 del NIST,” doi: 10.6028/NIST.CSWP.29.spa.

